



**SENTINELA**  
CLAREZA PARA DECIDIR, INTELIGÊNCIA PARA CRESCER

---

## NORMA DE RESPOSTA A INCIDENTES E CONTINUIDADE DE NEGÓCIOS

---

**Código:**  
NT-03

**Versão:**  
1.0

**Data de Emissão:**  
10/11/2025

**Público-Alvo:**  
Público Interno e Externo

**Aprovação:**  
Presidência

### 1 Objetivo

Estabelecer diretrizes, responsabilidades e procedimentos para identificação, registro, análise, resposta e tratamento de incidentes de segurança da informação, bem como garantir a continuidade das operações críticas da Sentinela Controladoria em caso de interrupções, incidentes cibernéticos ou desastres.

### 2 Escopo

Esta norma se aplica a todas as informações e dados da Sentinela Controladoria, em qualquer formato (digital ou físico), ao público interno (empregados, estagiários, sócios) e ao público externo (prestadores de serviço e parceiros) que tenham acesso ou façam uso dessas informações, sendo eles:

- 2.1 Incidentes de segurança da informação (falhas, ataques, vazamentos, indisponibilidades);
- 2.2 Acionamento e execução do Plano de Continuidade de Negócios (PCN) e do Plano de Recuperação de Desastres (PRD);
- 2.3 Processos de comunicação interna e externa relacionados à gestão de incidentes;
- 2.4 Processos de *backup*, retenção e restauração de dados.

### **3 Referências Normativas**

- 3.1 ISO/IEC 27001:2022 – Sistema de Gestão da Segurança da Informação;
- 3.2 ISO/IEC 27002:2022 – Controles de Segurança da Informação (itens 5.24, 5.29, 5.35 e 5.36);
- 3.3 ISO/IEC 27035:2023 – Gestão de Incidentes de Segurança da Informação;
- 3.4 ISO 22301:2019 – Continuidade de Negócios;
- 3.5 LGPD (Lei 13.709/2018): Art. 46 a 50 – Segurança e Boas Práticas;
- 3.6 Política de Segurança da Informação (PSI) da Sentinela Controladoria.

### **4 Definições**

#### **4.1 Incidente de Segurança da Informação**

Evento que compromete, ou tem potencial de comprometer, a confidencialidade, integridade ou disponibilidade de informações, sistemas ou serviços.

#### **4.2 Evento de Segurança**

Ocorrência observável em um sistema ou rede que pode indicar uma violação iminente ou em andamento.

#### **4.3 Continuidade de Negócios**

Capacidade de a organização manter funções críticas mesmo durante e após situações de interrupção.

#### **4.4 PRD (Plano de Recuperação de Desastres)**

Documento que define as estratégias e procedimentos para restabelecimento de sistemas e dados após falhas graves.

### **5 Responsabilidades**

As responsabilidades são segregadas por função para assegurar clareza e alinhamento com outras normas da organização.

## **5.1 Equipe de Tecnologia da Informação**

- 5.1.1 Coordenar a resposta a incidentes e aprovar as ações corretivas;
- 5.1.2 Avaliar a gravidade, impacto e criticidade dos incidentes reportados;
- 5.1.3 Aprovar o acionamento dos planos de continuidade (PCN/PRD);
- 5.1.4 Detectar, registrar e responder a eventos e incidentes;
- 5.1.5 Preservar evidências e elaborar relatórios técnicos;
- 5.1.6 Apoiar as áreas de negócio na execução das ações de recuperação.

## **5.2 Gestores**

- 5.2.1 Garantir que sua equipe cumpra esta Norma e receba treinamento e conscientização adequados sobre classificação e proteção de dados;
- 5.2.2 Comunicar imediatamente incidentes que afetem seus processos;
- 5.2.3 Garantir a execução dos planos de contingência definidos para sua unidade;
- 5.2.4 Apoiar a comunicação com clientes e parceiros quando necessário.

## **5.3 Funcionários e Terceiros**

- 5.3.1 Reportar imediatamente qualquer suspeita de incidente;
- 5.3.2 Seguir os procedimentos definidos nesta norma;
- 5.3.3 Cooperar com as investigações conduzidas pela equipe de segurança.

# **6 Diretrizes**

## **6.1 Detecção e Registro**

Todos os eventos de segurança devem ser monitorados, registrados e avaliados para determinar se configuram um incidente

## **6.2 Análise**

O Time de Tecnologia avaliará a causa raiz, o impacto e a extensão do incidente, classificando-o conforme criticidade.

## **6.3 Contenção**

Devem ser adotadas medidas imediatas para conter o incidente, mitigar danos e eliminar a causa do problema.

## **6.4 Recuperação**

Sistemas e serviços afetados devem ser restaurados de forma controlada, assegurando a integridade dos dados e verificando a inexistência de novas ameaças.

## **6.5 Lições Aprendidas**

Após o encerramento do incidente, deve ser elaborado um Relatório Pós-Incidente, contendo causas, impactos e recomendações preventivas.

## 6.6 Backup e Restauração

- 6.6.1 Todos os sistemas críticos devem possuir rotinas automáticas de *backup* configuradas e supervisionadas;
- 6.6.2 *Backups* devem ser criptografados e armazenados em local distinto do ambiente de produção;
- 6.6.3 Deve existir ao menos uma cópia *offline* (*air-gap*) para proteção contra *ransomware*;
- 6.6.4 A periodicidade mínima de execução dos backups será diária para dados críticos e semanal para dados de suporte;
- 6.6.5 Devem ser realizados testes de restauração trimestrais para validar a integridade e funcionalidade das cópias, os testes devem ser documentados e avaliados pelo Time de Tecnologia;
- 6.6.6 As cópias de segurança devem ser mantidas pelo período mínimo de 90 dias, salvo requisitos legais específicos;
- 6.6.7 Os planos de continuidade e recuperação devem ser acionados conforme os níveis de criticidade definidos no PCN e revisados após cada incidente significativo.

## 7 Comunicação de Incidentes

Todo incidente de segurança deve ser reportado imediatamente por *e-mail* institucional ou sistema designado ao Time de Tecnologia da Informação. Incidentes graves, que envolvam dados pessoais ou risco de interrupção de serviços críticos, devem ser comunicados à Direção e ao Encarregado de Proteção de Dados (DPO), conforme a LGPD. Caso o incidente afete dados de clientes ou parceiros, a comunicação externa deve ser realizada somente pela Direção ou DPO, evitando vazamento de informações não verificadas. Todas as comunicações devem ser registradas para fins de auditoria e conformidade.

## 8 Sanções

O descumprimento desta norma constitui falta grave e poderá resultar em medidas disciplinares, conforme o código de conduta da empresa. As sanções incluem, de forma gradual: advertência verbal ou escrita, suspensão, desligamento por justa causa, e, se cabível, medidas legais (cíveis e penais) contra os responsáveis. A Sentinela Controladoria poderá adotar ações legais nos casos de vazamento intencional de informações ou negligência grave na proteção de dados, em conformidade com a legislação vigente e contratos de trabalho. (ISO/IEC 27002, 5.35).

## 9 Revisão e Atualização

Esta norma será revisada anualmente ou a qualquer tempo em que ocorram mudanças relevantes no ambiente de negócios, nas tecnologias utilizadas, nos requisitos legais/regulatórios de proteção de dados ou nas melhores práticas internacionais que possam afetar as diretrizes aqui estabelecidas. A revisão é de responsabilidade do Comitê de Segurança da Informação em conjunto com a Presidência da Sentinela.